CI/CD 파이프라인에서 SBOM과 NVD 자동 매핑을 통한 소스 코드 취약점 탐지 기법 연구[1)]

어윤규*, 김태현*, 김서연*, 남수만**

Automated SBOM-NVD Mapping for Source Code Vulnerability Detection in CI/CD Pipelines

Yun Gyu Eo*, Tae Hyun Kim*, Seo Yeon Kim*, Su Man Nam**

Abstract

현대 소프트웨어 개발 환경에서 CI/CD 파이프라인은 배포 민첩성을 크게 향상시켰으나, 동시에 보안 결함이 운영 환경으로 자동 전파될 위험을 내포하고 있다. 이에 DevSecOps 관점의 정적 분석(SAST) 도구 도입이 확산되고 있으나, CodeQL 등과 같은 기존 도구들은 사전 정의된 규칙에 의존하는 구조로 인해 신규 공통 보안 취약점(CVE)을 실시간으로 반영하지 못하며, 전체 소스 코드를 관계형 데이터베이스로 변환해 전수 조사를 수행하는 방식은 파이프라인 지연을 초래한다는 한계가 있다.

본 논문은 이러한 문제를 해결하기 위해, 소프트웨어 구성요소 명세(SBOM)와 미국 국립취약점 데이터베이스(NVD)를 자동으로 매핑하여 소스 코드 취약점을 탐지하는 CI/CD 보안 파이프라인을 제안한다. 제안 파이프라인은 빌드 단계에서 프로젝트의 의존성 구성요소를 SBOM 형태로 자동 수집하고, NVD REST API를 통해 실시간 조회한 CVE 메타데이터와 매핑하여 분석 대상 코드 영역을 선별하는 구조를 갖는다. 사용자는 특정 CWE 카테고리나 CVSS 심각도 기준에 따라 선택적 분석을 수행할 수 있으며, 탐지 결과에 대해서는 대규모 언어 모델(LLM)을 연동해 수정 가이드라인을 제공하도록 설계한다.

제안 파이프라인은 SBOM을 단순 구성요소 목록이 아닌, 취약점 탐지 범위를 동적으로 결정하는 선별 기준으로 재정의한다는 점이 기존 방식과의 차별화이다. 이를 통해 신규 CVE 발생 시 전체 코드베이스를 재분석하지 않고도 영향받는 영역만 선택적으로 재평가할 수 있어, DevSecOps 환경에서 실시간 위협 대응과 분석 효율성을 동시에 확보할 수 있는 설계적 기반을 제공한다.

Key Words : CI/CD 파이프라인, SBOM, NVD, 소스 코드 취약점 탐지, DevSecOps

* 어윤규: 청주대학교 (디지털보안학과) 학부생, henry4787@cju.ac.kr
* 김태현: 청주대학교 (디지털보안학과) 학부생, kth08122570@cju.sc.kr
* 김서연: 청주대학교 (디지털보안학과) 학부생, seoyyeonk@cju.ac.kr
** 남수만, 청주대학교(디지털보안학과), 조교수, smnam@cju.ac.kr
1) 본 과제(결과물)는 2025년도 교육부 및 충청북도의 재원으로 충북RISE센터의 지원을 받아 수행된 지역혁신중심 대학지원체계(RISE)의 결과입니다.(2025-RISE-11-013-02)